

Cyber Security - Cryptography and Key Management Standard

1. Introduction

1.1 Background

Advanced Personnel Management (APM) must ensure that cryptographic controls are adequately assessed, authorised, resourced and implemented to protect the confidentiality, integrity, and authenticity of Information Assets

1.2 Purpose

This document details the standard of cryptographic technologies APM must adhere to, including how keys used to encrypt data are managed securely at APM. It outlines the use of technologies that are reliable, secure and proven to work effectively in maintaining confidentiality, integrity and authenticity of APM's **Information Assets** and mitigate the risk of unauthorised access and/or modification.

1.3 Scope

This standard applies to all APM IT Software Assets (internal or externally managed) and Cloud Service Providers that host APM Information Assets and use cryptography to protect data in transit and at rest.

2. Principles

Principle	Description
Sensitive information must be encrypted	Where sensitive APM Information Assets, which can include information held on behalf of customers, is stored or transmitted, cryptographic means must be used to secure that information.
Strength of cryptography corresponds with information classification levels	The type of cryptographic algorithm used to encrypt information must take into account the classification level of the information in accordance with the <i>APM Information Asset Classification and Handling Standard</i> .
Cryptographic keys must be securely managed	Generation, distribution, and storage of cryptographic keys must be undertaken securely to protect the confidentiality and integrity of the key itself.
Use only approved cryptographic algorithms	Only those cryptographic algorithms approved by APM are to be used to encrypt or digitally sign information – the use of other cryptographic algorithms (including those of a proprietary nature) in all other circumstances is prohibited.

3. Authorisation

The use of cryptography in the form of X.509 certificates and Transport Layer Security (TLS) encrypted communication is required to protect APM IT Assets unless not operationally feasible.

To ensure that cryptographic artefacts (X.509 certificates, keying materials) are issued by APM IT's Public Key Infrastructure or a trusted external Certificate Authority (CA), a request must be made and approved by the D&T Operations team. Cryptography requests shall be directed through the D&T Support Team and the request recorded within the IT Service Management application.

4. Cryptographic Requirements

4.1 Use of Approved Cryptographic Algorithms and Protocols

All cryptographic solutions used for data encryption and digital signing at APM must be internationally recognised and be subject to rigorous public scrutiny and verification of effectiveness. A list of secure algorithms that meet these requirements and their permitted uses within APM is provided below.

Cryptographic Algorithms/Protocols	Minimum Key Size	Permitted uses	Notes
Advanced Encryption Standard (AES)	128 bits (256 bits preferred)	<i>Encryption</i> Must not be used in Electronic Code Book (ECB) Mode.	AES-128 must be phased out by 2030.
Elliptic Curve Cryptography (ECC)	Base point order and key size of at least 224 bits.	<i>Encryption</i>	The curve used should be from those defined in the National Institute of Science and Technology (NIST) standard NIST SP 800-186.
RSA	2048 bits minimum however 3072 bits preferred (Refers to the size of the modulus used in the RSA calculation)	<i>Key Distribution Digital Signatures</i>	When using RSA for both encryption and signing, the key pair for encryption must be different from that for signing.
Secure Hash Algorithm (SHA-2)	SHA-256, SHA-384 and SHA-512 Block Size	<i>Hashing/Digital Signing</i>	
Diffie-Hellman (DH)	2048 bits minimum however 3072 bits preferred	<i>Key Distribution</i>	When used for key exchange, only ephemeral variants are to be used. Anonymous DH is not permitted for TLS key exchange. When DH a modulus and associated parameters are selected according to NIST SP 800-56A Rev. 3

Cryptographic Algorithms/Protocols	Minimum Key Size	Permitted uses	Notes
Elliptic Curve DH	224 bits	<i>Key Distribution</i>	When used for key exchange, only ephemeral variants are to be used. Anonymous DH is not permitted for TLS key exchange.
Elliptic Curve DSA	224 bits	<i>Digital Signatures</i>	NIST P-384 curve is preferred
Module-Lattice-Based Digital Signature Standard (ML-DSA)	192 bits (ML-DSA-65), 256 bits (ML-DSA-87) preferred.	<i>Digital Signatures</i>	ML-DSA should be used as per FIPS 204.
Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM)	192 bits (ML-KEM-768), 256 bits (ML-KEM-1024) preferred.	<i>Key Distribution</i>	ML-KEM should be used as per FIPS 203.

Post-Quantum cryptographic algorithms should be implemented in new systems and services where supported. When implementing post-quantum cryptography the use of FIPS 140-3 validated cryptographic modules is preferred, not required.

4.2 Cipher Suites for TLS

TLS Version	Approved Cipher Suites
1.2	TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 TLS_DHE_DSS_WITH_AES_256_GCM_SHA384 TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 TLS_DHE_DSS_WITH_AES_128_GCM_SHA256 TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 TLS_ECDHE_ECDSA_WITH_AES_256_CCM TLS_DHE_RSA_WITH_AES_256_CCM TLS_ECDHE_ECDSA_WITH_AES_256_CCM_8 TLS_DHE_RSA_WITH_AES_256_CCM_8 TLS_ECDHE_ECDSA_WITH_AES_128_CCM TLS_DHE_RSA_WITH_AES_128_CCM TLS_ECDHE_ECDSA_WITH_AES_128_CCM_8 TLS_DHE_RSA_WITH_AES_128_CCM_8.

1.3	TLS_AES_256_GCM_SHA384 TLS_AES_128_GCM_SHA256 TLS_AES_128_CCM_SHA256 TLS_AES_128_CCM_8_SHA256
-----	--

4.3 Encryption of Information at Rest

The following table outlines the requirements for the encryption of Information Assets at rest:

Information Classification	Uncontrolled Zone (e.g. Internet locations or customer devices)	Externally Controlled Zone (e.g. SaaS)	Semi-controlled Zone (e.g. private clouds, IaaS, PaaS)	Controlled Zone (e.g. Data stored within APM environment)
Public	NOT REQUIRED (But preferred)			
Internal	MUST use current ASD approved encryption	SHOULD use encryption	NOT REQUIRED (But preferred)	
Confidential		MUST use current ASD approved encryption		RISK BASED DECISION
Restricted				

4.4 Encryption of Information in Transit

The following table outlines the requirements for the encryption of Information Assets in transit:

Information Classification	Transmission over public networks or guest networks	Transmission over corporate networks	Transmission over secured networks
Public	NOT REQUIRED (But preferred)		
Internal	MUST use current ASD approved encryption		
Confidential			
Restricted			

5. Key Management

The following principles must be followed for all aspects of key management;

- Keys may only be distributed to and accessed by authorised staff within the IT Department (the Key Custodians);

Where possible X.509 certificates should be installed without the ability to be exported from the destination system;

- Keys should be updated once they are no longer valid, or if there is a risk of disclosure;
- Compromised or corrupted keys must be revoked;
- All access to and actions against keys and the APM Public Key Infrastructure (PKI) are captured at time of issue;
- When necessary, certificates can be configured to be automatically issued to certain devices to facilitate secured communication (Workstation Certificates, Mobile Device Certificates etc.);

The loss of any keys, X.509 certificates or other cryptographic materials must be immediately reported to the IT Security Team;

The loss of any keys, X.509 certificates or other cryptographic materials must also be reported to the relevant contract or government body when necessary to satisfy contractual requirements.

Where possible, recovery of encrypted data should be supported in the case of lost, damaged or failed encryption key

Where possible keys must be rotated on a regular basis in line with the table below

Environment	Internet Facing / Production Data	Maximum Age
Production	Yes	60 days
Production	No	90 days
Non-Production	Yes	90 days
Non-Production	No	180 Days

Public Key Infrastructure (PKI)

APM utilises reputable Certification Authorities to obtain public facing certificates. Internal certificates will be issued from APM's Internal Certificate Authority. Wherever feasible, international standard specifications and best practice guidance shall be utilised in the implementation and management of internal PKI systems.

When exposing web services to the public internet, or when data will be consumed by a third party it is recommended that a commercial Trusted Certificate Authority be utilised for the issuing of an X.509 certificate. Due to increased risk, wildcard certificates must not be used.

Web services or applications that will be consumed internally should utilise an X.509 certificate issued by APM's PKI certificate platform. All APM Assets that consume the service or access the encrypted data are configured to trust APM's PKI platform as a Trusted Certification Provider.

Post Quantum Cryptography

Where possible systems should support use of quantum-resistant cryptographic algorithms to protect against the risks posed to data by a Cryptographically Relevant Quantum Computer (CRQC).

Cryptographic Algorithms	Approved Strengths	Notes
Advanced Encryption Standard (AES)	AES-256	AES-128 and AES-192 will not be approved beyond 2030
Secure Hash Algorithm 2 (SHA-2)	SHA-384 SHA-512	SHA-224 and SHA-256 will not be approved beyond 2030
Module-Lattice-Based Key Encapsulation Mechanism (ML-KEM)	ML-KEL-1024	ML-KEM-768 will not be approved beyond 2030
Module-Lattice-Based Digital Signature Algorithm (ML-DSA)	ML-DSA-87	ML-DSA-65 will not be approved beyond 2030

Post-quantum traditional hybrid schemes may be used during the transition to a full post-quantum cryptography implementation to facilitate interoperability during the migration.

6. Related Legislation or Documents

- *Information Asset Classification and Handling Standard*

7. Review

Update this document whenever requirements change and review at least once a year.

8. Definitions

Term	Definition / Explanation / Details
Australian Signals Directorate (ASD)	The Australian Signals Directorate (ASD) is an Australian Government intelligence agency that provides advice and assistance on security and integrity of information and communications.
Certification Authorities (CA)	The entity in a Public Key Infrastructure (PKI) that is responsible for issuing public-key certificates and exacting compliance to a PKI policy.
Cryptographic Algorithm	A mathematical algorithm, used in conjunction with a secret key, that transforms original input into a form that is unintelligible without special knowledge of the secret information and the algorithm. Such algorithms are also the basis for digital signatures and key exchange.
Cryptographic Key	A parameter used with a cryptographic algorithm that determines its operation in such a way that an entity with knowledge of the key can reproduce or reverse the operation, while an entity without knowledge of the key cannot.
Encryption Key	Specifies the particular transformation used to convert plaintext into ciphertext, or ciphertext to plaintext.
Information Assets	An information asset is a body of information that has financial value to an organization.
Internal Certificate Authority	A self-hosted 'internal' certificate authority distributes digital certificates which are used to verify that everyone is who they say they are. Internal certificates are usually only used within an organisation and are really only 'trusted' by users within that organisation.
IT Assets	Collective term for IT Equipment Assets (physical IT devices) and IT Software Assets (applications software or systems software).
IT Software Assets	The IT software used to process, store or disseminate information assets. This will include both purchased software and freeware and any cloud service (Software as a System as an example).
Keying Materials	Cryptographic keys generated or used by cryptographic equipment or software.
Public facing certificates	Certificates are used for public-facing website projects (e.g., websites, landing pages, microsites, etc.) and are needed in order to avoid browser warnings. A public certificate can be used to secure either server-to-client or server-to-server communication and can only be issued by a trusted certification authority (CA).

Term	Definition / Explanation / Details
Public Key Infrastructure (PKI)	A supporting infrastructure that utilises trusted authorities to vouch for the identity of 3rd party systems or people.
X.509 Certificate	An X.509 certificate is a digital certificate that authenticates a website's identity and enables an encrypted connection using Transport Layer Security (TLS).
Trusted Certification Provider	A trusted certificate authority — or what's also known as a commercial certificate authority — is a third-party entity that issues certificates for organizations that request them. They're not controlled in any way by the person or organization that requests a certificate from them. A trusted CA issues publicly trusted digital certificates that meet at least the minimum regulatory standards (aka baseline requirements, or BRs) that are outlined by the CA/Browser Forum (CA/B Forum).
Wildcard Certificate	A public key certificate which can be used with multiple sub-domains of a domain.